

Vulnerability Report: Missing Rate Limiting in OTP Generation

Summary

The OTP (One-Time Password) generation functionality at the mobile number verification endpoint does not implement proper rate limiting controls. An attacker can repeatedly trigger OTP requests for the same mobile number without restriction. During testing, more than 400 OTP requests were successfully generated for a single mobile number without any blocking mechanism or cooldown enforcement.

Affected Endpoint

Endpoint: [https://\[REDACTED\]/v2/loginSignup](https://[REDACTED]/v2/loginSignup)

Functionality: Mobile Number Verification / OTP Generation

Vulnerability Type

- Missing Rate Limiting
- Business Logic Flaw
- Improper Abuse Protection
- OTP Flooding / SMS Bombing Risk

Steps to Reproduce

- 1 Navigate to the mobile number verification page.
- 2 Enter a valid mobile number.
- 3 Intercept the 'Send OTP' request using a proxy tool such as Burp Suite.
- 4 Send the captured request to Burp Intruder or Sequencer.
- 5 Start automated or repeated requests using the same mobile number.
- 6 Observe that the server generates new OTPs without any rate limiting or restriction.

Security Impact

- OTP flooding / SMS bombing against victims.
- Financial loss due to excessive SMS delivery costs.
- Increased risk of OTP brute-force or account abuse.
- Negative impact on user trust and platform reputation.

Recommended Remediation

- Implement strict rate limiting on the OTP generation endpoint.
- Enforce a cooldown period (30–60 seconds) between OTP requests.
- Limit maximum OTP requests per mobile number per hour/day.
- Implement CAPTCHA after multiple OTP attempts.
- Monitor and log abnormal OTP request behavior.

Responsible Disclosure Statement

Reported by Prince Roy, Cybersecurity Researcher. This vulnerability was identified during responsible security testing and is reported in good faith to help improve platform security. No user data was harmed, and testing was limited to minimal proof-of-concept validation.